

AWS SAA-C03

Security

IAM, KMS, CloudHSM, ACM, WAF, Shield, GuardDuty, Inspector, Macie, Cognito

Solutions Architect Associate

Dispensa di Studio Approfondita

AWS IAM: il fondamento della sicurezza

IAM (Identity and Access Management) e' il servizio che controlla chi puo' fare cosa nel tuo account AWS. Ogni singola azione in AWS, che sia lanciare un'istanza EC2, leggere un oggetto da S3 o creare una tabella DynamoDB, passa attraverso IAM. Capire IAM in profondita' e' assolutamente essenziale per l'esame SAA-C03.

Utenti, Gruppi e Ruoli

Un IAM User rappresenta una persona o un'applicazione che interagisce con AWS. Ogni utente puo' avere credenziali per la console (password) e/o credenziali programmatiche (access key ID + secret access key). La best practice e' non usare mai l'utente root per le operazioni quotidiane: crea un utente IAM con permessi di amministratore e usa quello.

I Groups sono raccolte di utenti. Quando assegni una policy a un gruppo, tutti gli utenti del gruppo ereditano quei permessi. Ad esempio, puoi creare un gruppo "Developers" con permessi su EC2 e S3, e un gruppo "DBAdmins" con permessi su RDS. Un utente puo' appartenere a piu' gruppi. I gruppi non possono contenere altri gruppi.

I Roles sono identita' temporanee che possono essere "assunte" da utenti, servizi AWS o entita' esterne. A differenza degli utenti, i ruoli non hanno credenziali permanenti: quando qualcuno assume un ruolo, riceve credenziali temporanee tramite STS (Security Token Service) che scadono dopo un periodo configurabile.

I casi d'uso piu' importanti dei ruoli per l'esame sono: EC2 Instance Role (permette a un'istanza EC2 di accedere ad altri servizi AWS senza dover memorizzare access key nel codice), Cross-Account Role (permette a utenti di un altro account AWS di accedere alle tue risorse), e Service-Linked Role (ruoli predefiniti che i servizi AWS usano per operare nel tuo account).

SUGGERIMENTO ESAME: Se la domanda chiede "come permettere a un'istanza EC2 di accedere a S3 in modo sicuro", la risposta e' sempre un IAM Role associato all'istanza, MAI access key hardcoded nel codice o nell'istanza.

Policy IAM: il linguaggio dei permessi

Le policy IAM sono documenti JSON che definiscono i permessi. Ogni policy contiene uno o piu' statement con questi elementi: Effect (Allow o Deny), Action (quali operazioni, es. s3:GetObject), Resource (su quali risorse, es. arn:aws:s3:::my-bucket/*), e opzionalmente Condition (condizioni aggiuntive, es. solo da un certo IP o solo con MFA).

Ci sono tre tipi di policy: AWS Managed Policies (create e mantenute da AWS, come AmazonS3ReadOnlyAccess), Customer Managed Policies (create da te, riutilizzabili tra utenti/gruppi/ruoli), e Inline Policies (incorporate direttamente in un singolo utente/gruppo/ruolo, non riutilizzabili).

La logica di valutazione delle policy segue un principio fondamentale: di default tutto e' negato (implicit deny). Se una

policy concede un Allow, l'azione e' permessa. Ma se qualsiasi policy contiene un Deny esplicito, questo vince sempre su qualsiasi Allow. In sintesi: Explicit Deny > Allow > Implicit Deny.

I Permission Boundaries sono un meccanismo avanzato che definisce il massimo dei permessi che un utente o ruolo puo' avere. Anche se una policy concede un permesso, se il Permission Boundary non lo include, l'azione e' negata. Sono utili per delegare la creazione di ruoli senza rischiare escalation di privilegi.

MFA e sicurezza dell'account

Multi-Factor Authentication (MFA) aggiunge un secondo fattore di autenticazione oltre alla password. AWS supporta dispositivi MFA virtuali (app come Google Authenticator), token hardware U2F (YubiKey) e token hardware TOTP. E' fortemente raccomandato abilitare MFA sull'account root e su tutti gli utenti con accesso alla console.

Puoi anche richiedere MFA nelle policy IAM usando la condizione `aws:MultiFactorAuthPresent`. Ad esempio, puoi permettere la cancellazione di oggetti S3 solo se l'utente ha completato l'autenticazione MFA.

SUGGERIMENTO ESAME: Se la domanda chiede "come proteggere operazioni critiche come la cancellazione di risorse", la risposta spesso coinvolge una policy con condizione MFA.

Service Control Policies (SCP)

Le SCP fanno parte di AWS Organizations e definiscono i limiti massimi di permessi per gli account o le Organizational Units (OU). Le SCP non concedono permessi: li limitano. Anche se un utente ha una policy che concede un'azione, se la SCP dell'account non la permette, l'azione e' negata.

Le SCP non si applicano al management account (l'account principale dell'organizzazione). Questo e' un dettaglio importante per l'esame.

SUGGERIMENTO ESAME: "Impedire a tutti gli utenti di un account di usare una regione specifica" o "impedire la disabilitazione di CloudTrail" = SCP in AWS Organizations.

Crittografia: KMS, CloudHSM e ACM

AWS KMS: gestione centralizzata delle chiavi

AWS KMS (Key Management Service) e' il servizio centrale per la crittografia in AWS. Quasi tutti i servizi AWS che offrono crittografia (S3, EBS, RDS, DynamoDB, ecc.) si integrano con KMS per la gestione delle chiavi.

KMS gestisce Customer Master Keys (CMK), ora chiamate semplicemente KMS Keys. Ci sono tre tipi: AWS Managed Keys (create e gestite automaticamente da AWS per ogni servizio, con nome aws/s3, aws/ebs, ecc.), Customer Managed Keys (create e gestite da te, con pieno controllo su policy, rotazione e audit), e AWS Owned Keys (usate internamente da AWS, non visibili nel tuo account).

Le chiavi KMS possono essere simmetriche (AES-256, usate dalla maggior parte dei servizi AWS) o asimmetriche (RSA o ECC, per operazioni di encrypt/decrypt o sign/verify fuori da AWS). Le chiavi simmetriche non lasciano mai KMS in chiaro: le operazioni di crittografia avvengono all'interno del servizio.

Per criptare grandi quantita' di dati, KMS usa l'Envelope Encryption. Il processo e': chiami GenerateDataKey, KMS ti restituisce una data key in chiaro e una copia criptata della stessa. Usi la data key in chiaro per criptare i tuoi dati localmente, poi la scarti e conservi solo la versione criptata insieme ai dati. Per decryptare, invii la data key criptata a KMS che te la restituisce in chiaro.

La rotazione automatica delle chiavi e' disponibile per le Customer Managed Keys: ogni anno viene generata una nuova chiave crittografica, ma il key ID rimane lo stesso. I dati criptati con la vecchia chiave possono ancora essere decryptati.

Le Multi-Region Keys sono repliche della stessa chiave in piu' regioni. Hanno lo stesso materiale crittografico, quindi i dati criptati in una regione possono essere decryptati in un'altra senza dover ri-criptare. Utili per disaster recovery e applicazioni globali.

SUGGERIMENTO ESAME: "Audit trail di chi ha usato una chiave di crittografia" = KMS con Customer Managed Key (CloudTrail registra ogni chiamata). "Crittografia con controllo completo sulle chiavi" = Customer Managed Key. "Crittografia di default senza gestione" = AWS Managed Key.

AWS CloudHSM

CloudHSM fornisce Hardware Security Module dedicati nel cloud. A differenza di KMS dove AWS gestisce l'infrastruttura delle chiavi, con CloudHSM hai il controllo esclusivo: AWS non ha accesso alle tue chiavi. I moduli sono certificati FIPS 140-2 Level 3 (KMS e' Level 2).

CloudHSM e' la scelta quando hai requisiti di compliance stringenti che richiedono hardware dedicato, quando devi fare SSL/TLS offloading ad alte prestazioni, o quando usi Oracle Transparent Data Encryption (TDE). I cluster CloudHSM

possono essere distribuiti su piu' AZ per alta disponibilita'.

SUGGERIMENTO ESAME: "FIPS 140-2 Level 3" o "controllo esclusivo delle chiavi" o "Oracle TDE" = CloudHSM.

AWS Certificate Manager (ACM)

ACM gestisce certificati SSL/TLS. Puoi richiedere certificati gratuiti emessi da Amazon o importare certificati di terze parti. I certificati emessi da ACM si rinnovano automaticamente.

ACM si integra nativamente con ALB, CloudFront, API Gateway e NLB. Per EC2, non puoi usare certificati ACM direttamente: devi importare il certificato manualmente sull'istanza.

SUGGERIMENTO ESAME: "Certificato SSL gratuito con rinnovo automatico per un ALB" = ACM.

Protezione delle applicazioni: WAF, Shield, Firewall Manager

AWS WAF

AWS WAF (Web Application Firewall) protegge le applicazioni web da attacchi comuni come SQL injection, cross-site scripting (XSS), e bot malevoli. Si applica a CloudFront, ALB, API Gateway e AppSync.

WAF funziona con Web ACL (Access Control List) che contengono regole. Le regole possono essere: IP match (blocca o permetti IP specifici), geo match (blocca traffico da paesi specifici), rate-based (blocca IP che superano una soglia di richieste al secondo), string/regex match (cerca pattern nelle richieste), e size constraint (limita la dimensione delle richieste).

AWS fornisce Managed Rule Groups predefiniti che coprono le vulnerabilità OWASP Top 10, la protezione da bot, e pattern di attacco noti. Puoi combinare regole managed con regole custom.

SUGGERIMENTO ESAME: "Proteggere un'applicazione web da SQL injection" = WAF su ALB o CloudFront. "Bloccare IP che fanno troppe richieste" = WAF rate-based rule.

AWS Shield

Shield protegge dagli attacchi DDoS (Distributed Denial of Service). Shield Standard è gratuito e automaticamente attivo per tutti i clienti AWS. Protegge dagli attacchi più comuni a Layer 3 e Layer 4 (SYN flood, UDP reflection, ecc.).

Shield Advanced costa \$3000 al mese e offre protezione avanzata per EC2, ELB, CloudFront, Global Accelerator e Route 53. Include: protezione DDoS a Layer 7, accesso al DDoS Response Team (DRT) di AWS 24/7, metriche e report avanzati, e cost protection (AWS rimborsa i costi di scaling causati da un attacco DDoS).

SUGGERIMENTO ESAME: "Protezione DDoS avanzata con supporto 24/7" = Shield Advanced. "Protezione DDoS base" = Shield Standard (già incluso).

AWS Firewall Manager

Firewall Manager permette di gestire centralmente le regole di sicurezza su più account in un'organizzazione AWS. Puoi definire policy di sicurezza per WAF, Shield Advanced, Security Groups e Network Firewall, e applicarle automaticamente a tutti gli account e le risorse.

SUGGERIMENTO ESAME: "Gestire WAF rules su tutti gli account dell'organizzazione" = Firewall Manager.

Rilevamento delle minacce: GuardDuty, Inspector, Macie

Amazon GuardDuty

GuardDuty è un servizio di threat detection intelligente che analizza continuamente diverse fonti di dati: CloudTrail Management Events, CloudTrail S3 Data Events, VPC Flow Logs, DNS Logs, e opzionalmente EKS Audit Logs e Lambda Network Activity.

Usando machine learning e threat intelligence, GuardDuty rileva attività sospette come: account compromessi (chiamate API da IP malevoli, disabilitazione di logging), istanze compromesse (comunicazione con server di command & control, crypto mining), e reconnaissance (scansione di porte, enumerazione di risorse).

I findings di GuardDuty possono essere inviati a EventBridge per attivare risposte automatiche. Ad esempio, puoi configurare una Lambda che isola automaticamente un'istanza compromessa modificando il suo Security Group.

SUGGERIMENTO ESAME: "Rilevare attività sospette nell'account AWS" o "rilevare crypto mining su EC2" = GuardDuty.

Amazon Inspector

Inspector esegue vulnerability assessment automatizzati su istanze EC2, immagini container in ECR e funzioni Lambda. Scansiona per vulnerabilità note (CVE), problemi di network reachability e deviazioni dalle best practice.

Inspector assegna un severity score a ogni finding e suggerisce la remediation. Si integra con Security Hub per una vista centralizzata.

Amazon Macie

Macie usa machine learning per scoprire e proteggere dati sensibili (PII, dati finanziari, credenziali) nei bucket S3. Classifica automaticamente i dati e genera alert quando rileva accessi anomali o configurazioni rischiose.

SUGGERIMENTO ESAME: "Scoprire dati sensibili in S3" = Macie. "Vulnerability scanning su EC2 e container" = Inspector.

Gestione delle identità: Cognito, IAM Identity Center

Amazon Cognito

Cognito gestisce l'autenticazione e l'autorizzazione per applicazioni web e mobile. Ha due componenti principali.

User Pools sono directory di utenti. Gestiscono la registrazione, il login, il recupero password, e l'MFA. Supportano social login (Google, Facebook, Apple), SAML e OpenID Connect. Quando un utente si autentica, User Pool restituisce un JWT token che l'applicazione usa per le chiamate API.

Identity Pools (Federated Identities) forniscono credenziali AWS temporanee per accedere direttamente ai servizi AWS (S3, DynamoDB, ecc.). Possono autenticare utenti da User Pools, social providers, SAML, o anche utenti anonimi (guest access).

Il flusso tipico è: l'utente si autentica con User Pool, riceve un JWT token, lo presenta a Identity Pool, che restituisce credenziali AWS temporanee con permessi definiti da un IAM Role.

SUGGERIMENTO ESAME: "Autenticazione per un'app mobile con social login" = Cognito User Pools. "Accesso diretto a S3 da un'app mobile" = Cognito Identity Pools. Spesso la risposta coinvolge entrambi.

AWS IAM Identity Center (ex SSO)

IAM Identity Center fornisce Single Sign-On centralizzato per tutti gli account AWS nell'organizzazione e per applicazioni cloud di terze parti (Salesforce, Slack, ecc.). Si integra con Active Directory (on-premises o AWS Managed AD) e con identity provider SAML 2.0.

I Permission Sets definiscono i permessi che un utente ha in ogni account AWS. Puoi assegnare permission set diversi allo stesso utente per account diversi.

SUGGERIMENTO ESAME: "SSO per accedere a più account AWS" = IAM Identity Center.

Gestione dei segreti: Secrets Manager e Parameter Store

AWS Secrets Manager

Secrets Manager e' progettato specificamente per gestire segreti come password di database, API key e token. La sua caratteristica distintiva e' la rotazione automatica: puo' ruotare automaticamente le credenziali di RDS, Redshift e DocumentDB senza downtime per l'applicazione.

Secrets Manager cripta i segreti con KMS e fornisce un'API per recuperarli programmaticamente. Le applicazioni non devono mai memorizzare segreti nel codice o nei file di configurazione.

AWS Systems Manager Parameter Store

Parameter Store e' un key-value store per configurazioni e segreti. E' piu' semplice e meno costoso di Secrets Manager. I parametri possono essere String, StringList o SecureString (criptato con KMS).

Parameter Store supporta una gerarchia di parametri (es. /app/prod/db-password, /app/dev/db-password) e policy di accesso granulari tramite IAM. Non ha rotazione automatica nativa (devi implementarla tu con Lambda).

SUGGERIMENTO ESAME: "Rotazione automatica delle credenziali del database" = Secrets Manager. "Configurazioni e segreti con costo minimo" = Parameter Store. Se la domanda non menziona la rotazione, Parameter Store e' spesso sufficiente.

AWS Directory Service

AWS Managed Microsoft AD e' un Active Directory completo gestito da AWS. Supporta trust bidirezionale con AD on-premises, permettendo agli utenti on-premises di accedere a risorse AWS e viceversa. E' la scelta per workload che richiedono un AD completo (applicazioni .NET, SQL Server, SharePoint).

AD Connector e' un proxy che reindirizza le richieste di autenticazione al tuo AD on-premises. Non memorizza dati in cloud. E' la scelta quando vuoi usare il tuo AD esistente senza replicarlo in AWS.

Simple AD e' una directory standalone basata su Samba, per esigenze semplici e piccole (fino a 5000 utenti). Non supporta trust con altri AD.

SUGGERIMENTO ESAME: "Estendere Active Directory on-premises in AWS" = AWS Managed Microsoft AD con trust. "Usare AD on-premises per autenticazione AWS senza replica" = AD Connector.